

Mapeo de Preguntas de la Encuesta a Requisitos Normativos y Marcos de Referencia

Nota: Este mapeo es orientativo. Debe revisarse y adaptarse a cada sector y jurisdicción concreta.

Nº Pregunta	Tema principal	Fase PASTA / STRIDE	Normas / Marcos relacionados (ejemplos)
2.1.1	Estrategia formal de ciberseguridad	Fase 1 (negocio)	NIS2 (gobernanza y responsabilidad de la alta dirección), ENS (política de seguridad), ISO 27001 (A.5, organización de seguridad) [web:21] [web:27]
2.1.2	Información periódica a la Alta Dirección	Fase 1	NIS2 (supervisión del riesgo cibernético por el órgano de dirección), DORA (gobernanza del riesgo TIC), buenas prácticas de Deloitte/ISMS Forum [web:8][web:21] [web:31]
2.1.3	Comités ciberseguridad–negocio	Fase 1	NIS2, DORA, ISO 27001 (A.5), directrices de gobernanza corporativa [web:8] [web:21]
2.2.1	Referencia explícita a modelado de amenazas	PASTA global	OWASP SAMM (práctica de Threat Modeling), buenas prácticas de NIST y guías de modelado de amenazas [web:18] [web:39]
2.2.2	Revisión periódica de modelos	PASTA 4–6	Ciclo de mejora continua ISO 27001, ENS (revisión periódica), NIS2 (gestión continua del riesgo) [web:21] [web:27]
3.1.1	Objetivos de negocio vinculados a seguridad	Fase 1	NIS2, DORA (impacto operacional), ISO 27005 (contexto y criterios de riesgo) [web:21][web:24]

3.1.2	Mapeo a impactos de negocio cuantificables	Fase 7	ISO 27005, metodologías de riesgo, mejores prácticas de reporting a dirección [web:8][web:31]
3.1.3	Integración de requisitos normativos en modelos	Fase 1–4	NIS2, DORA, RGPD (art. 32), ENS (análisis de riesgo), regulaciones sectoriales [web:21][web:24][web:27]
4.1.1	Inventario de activos	Fase 2	ISO 27001 (A.5, A.8), ENS (inventario de activos), NIS2 (activos esenciales) [web:21][web:27]
4.1.2	Cobertura de modelos sobre activos críticos	Fase 2–4	Buenas prácticas de gestión de riesgo (ISO 27005), OWASP SAMM [web:18][web:39]
4.1.3	Documentación de arquitectura y flujos	Fase 2–3	NIST, OWASP Threat Modeling, ENS (documentación de sistemas) [web:18][web:39]
5.1.1	DFDs y límites de confianza	Fase 3	STRIDE, OWASP Threat Modeling, SAMM [web:18][web:28][web:39]
5.1.2	Identificación de trust boundaries	Fase 3	STRIDE, Zero Trust (NIST SP 800-207), marcos Zero Trust sectoriales [web:12][web:28]
6.1.1	Metodologías utilizadas (PASTA, STRIDE, etc.)	Fase 4	OWASP SAMM (Threat Modeling), prácticas de modelado reconocidas [web:18][web:39]
6.1.2	Momento del ciclo de vida para Threat Modeling	Fase 4	DevSecOps, SDLC seguro, OWASP Software Assurance [web:18][web:39]
6.1.3	Frecuencia de modelado	Fase 4	Mejora continua ISO 27001, ENS, NIS2 [web:21][web:27]

6.2.x	Preguntas por categoría STRIDE	Fase 4	STRIDE, OWASP, controles asociados (identidad, integridad, logging, confidencialidad, disponibilidad, privilegios) [web:18] [web:28][web:39]
7.1.1	Vinculación amenazas-vulnerabilidades	Fase 5	ISO 27001 (A.12), procesos de gestión de vulnerabilidades, guías de Threat Modeling [web:18][web:39]
7.1.2	Tiempo de cierre de vulnerabilidades	Fase 5	SLAs internos, recomendaciones de NIST/ENISA sobre tiempos de remediación [web:18]
7.1.3	Uso de CVSS u otros métodos	Fase 5-7	CVSS, ISO 27005, marcos GRC [web:18]
8.1.1	Simulaciones de ataque (red teaming, etc.)	Fase 6	Ejercicios de ciber crisis, recomendaciones ENISA y NIS2 [web:21] [web:24]
8.1.2	Cobertura de simulaciones	Fase 6	Buenas prácticas de resiliencia, ciber crisis nacionales [web:21]
8.1.3	Documentación de lecciones aprendidas	Fase 6-7	Gestión de incidentes, mejora continua (ISO 27001 A.16) [web:21] [web:27]
9.1.1	Integración de resultados en metodología de riesgo	Fase 7	ISO 27005, NIS2 (gestión basada en riesgo), ENS [web:21] [web:27]
9.1.2	Cuantificación económica del riesgo	Fase 7	Prácticas de análisis cuantitativo de riesgo, DORA (impacto financiero) [web:24]
9.1.3	Uso de IGM de ciberseguridad	Fase 7	Indicadores de madurez (ISMS Forum, Cisco, etc.) [web:31] [web:38][web:40]

9.1.4	Medición de ROI de ciberseguridad	Fase 7	Marco de negocio de ciberseguridad, reporting a consejos [web:8]
10.1.1	Estrategia Zero Trust	Fase transversal	NIST SP 800-207, estrategias Zero Trust nacionales, marcos de referencia industriales [web:12]
10.1.2	Threat Modeling de terceros y cadena de suministro	Fase 2–4	NIS2 (gestión de terceros), DORA (terceros TIC), recomendaciones ENISA [web:21] [web:24]
11.1.1	Recursos humanos dedicados	CAP	Indicadores de madurez y capacidades (ISMS Forum, Cisco) [web:31][web:38]
11.1.2	Nivel de especialización en PASTA/STRIDE	CAP	Demandas de capacidades en ciberseguridad (estrategias nacionales, Digital Spain 2025) [web:24][web:30]
11.1.3	Uso de herramientas específicas	CAP	OWASP SAMM, madurez de prácticas de Threat Modeling [web:18][web:39]
11.1.4	Automatización del Threat Modeling	CAP	DevSecOps, prácticas avanzadas de seguridad, integración CI/CD [web:18] [web:39]

Este mapeo puede ampliarse con referencias específicas de cada sector (financiero, sanitario, energético, etc.) y de guías de autoridades nacionales como INCIBE y CCN-CERT.